

Information Assurance and Security

Weeks 3 & 4 — Governance and Risk Management

College of Computer Studies

University of Perpetual Help System DALTA

Where we are in the course

Weeks 1 and 2 named the problem. Weeks 3 and 4 build the response.

WEEKS 1-2

What we protect and what threatens it

The CIA Triad, threats, vulnerabilities, risk, attackers, and attack vectors.

Done

WEEK 3

The rules an organization sets

Security policies, the standards behind them, and ISO 27001 as the governing frame.

Now

WEEK 4

How it decides which rules it needs

Risk management: identify, analyse, evaluate, and treat, as a repeatable process.

Next

WEEK THREE

Security Policies, Standards, and Practices

Governance, ISO 27001, and the documents that run security

Why security needs written rules

A control that lives only in one person's head is not a control. It is a habit, and habits leave when people do.



Consistency

Everyone handles the same situation the same way, whether or not the expert is in the room.



Accountability

When a rule is written down, you can tell whether it was followed. Unwritten rules cannot be broken or kept.



Continuity

The organization keeps its security knowledge even when individual staff leave.



Defensibility

After an incident, a regulator asks to see the policy. "We meant to" is not an answer.

Four kinds of document, from broad to specific

They are not synonyms. Each sits at a different level and answers a different question.

Policy

WHAT and WHY

A short, high-level statement of intent, approved by management.

"We protect the confidentiality of student data."

Standard

WHAT, exactly

A mandatory, measurable requirement that makes a policy concrete.

"Passwords are at least 12 characters."

Procedure

HOW, step by step

The exact sequence to follow. Removes guesswork.

"To reset a password: 1, 2, 3..."

Guideline

HOW, suggested

Recommended good practice. Advisory, not mandatory.

"Consider a passphrase you can remember."

Policy and standard, side by side

The two most confused, and the two that matter most for compliance

Policy

Intent · Rarely changes

- Says what must be true and why
- Approved at management level
- Technology-neutral, so it lasts
- Short - often a single page

The board can read it and mean it.

Standard

Requirement · Changes as technology does

- Says exactly what counts as compliant
- Mandatory and measurable
- Names specific numbers and tools
- Auditable - pass or fail

The auditor can test it and prove it.

ISO 27001, past the overview

You met the ISMS idea. Here is what the standard is actually built from.

Clauses 4-10

The mandatory core

Seven clauses every certified organization must satisfy: context, leadership, planning, support, operation, evaluation, improvement. Non-negotiable.

Annex A

The control catalogue

93 reference controls in four themes. You pick the ones your risk assessment justifies - you do not have to use them all.

The SoA

Statement of Applicability

The document linking the two: for each Annex A control, whether it applies, and why. The auditor's first stop.

Annex A: the 93 controls, in four themes

The 2022 revision reorganized dozens of controls into four plain groups



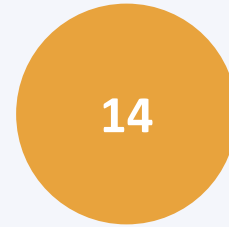
Organizational

Policies, roles, supplier relationships, and how the whole ISMS is run.



People

Screening, awareness training, and what happens when someone joins or leaves.



Physical

Locks, secure areas, clean-desk rules, and protecting equipment and media.



Technological

Access control, encryption, logging, backups, and secure development.

The policies almost every organization needs

Concrete examples, framed for a school or company you would recognize

Acceptable Use

What staff and students may and may not do with systems and accounts.

Access Control

Who gets access to what, on what basis, and how it is removed when they leave.

Data Classification

How information is labelled so people know how carefully to handle it.

Incident Response

What to do, and who to tell, the moment something goes wrong.

Password / Authentication

The rules that keep accounts from being the weakest link.

Backup and Recovery

What is copied, how often, and proof that restoring actually works.

A policy is not done when it is written

It runs on the same Plan-Do-Check-Act loop as the whole ISMS

1

Draft and approve

Written, reviewed, and signed off by someone with the authority to enforce it.

2

Communicate

Published and explained. A policy nobody has read protects nobody.

3

Enforce and monitor

Applied consistently, with a way to tell whether it is actually being followed.

4

Review and update

Revisited on a schedule and after incidents, because the threats keep moving.

The most common failure is step 4. A password policy written in 2015 and never revisited is a liability, not a control.

KNOWLEDGE CHECK

Question 1 of 4

A one-page management statement that says student data must be kept confidential is a...

A

Standard

B

Procedure

C

Policy

D

Guideline

KNOWLEDGE CHECK

Question 2 of 4

"Passwords must be at least 12 characters" is best described as a...

A

Policy

B

Standard

C

Guideline

D

Procedure

KNOWLEDGE CHECK

Question 3 of 4

In ISO 27001, the document that records which Annex A controls apply and why is the...

A

Risk register

B

**Statement of
Applicability**

C

Audit log

D

Acceptable Use Policy

KNOWLEDGE CHECK

Question 4 of 4

You do not have to implement all 93 Annex A controls. What decides which ones you use?

A

Company size

B

The risk assessment

C

The IT budget

D

Government mandate

WEEK FOUR

Risk Management

Turning threat, vulnerability, and risk into decisions you can defend

What risk management actually is

The ongoing work of finding what could go wrong, deciding how much it matters, and choosing what to do about it - on purpose, before it happens.



It is continuous

Not a one-time audit. The register is a living document, revisited as things change.



It is comparative

Its value is letting you rank unlike risks on one scale and spend where it matters most.



It is honest about limits

You cannot fix everything. Risk management is how you choose what to leave, knowingly.

The risk management cycle

ISO 27005 and Clause 6.1, as one repeating loop



Steps 1 to 4 are last week's Clause 6.1. Step 5, Monitor, is what makes it management rather than a one-off assessment.

Analysing risk: the likelihood-impact matrix

How a vague worry becomes a comparable, rankable number

LIKELIHOOD →	Med	High	Critical
	Low	Med	High
	Low	Low	Med
	IMPACT →		

Reading the matrix

- Likelihood times impact gives a colour and a rank.
- A rare but catastrophic risk can outrank a frequent nuisance.
- The colours set priority: red first, then amber, then teal.
- The scale is a shared language, not a precise measurement.

The point is not the exact number. It is that two people, given the same facts, land in the same box.

Before and after: inherent vs residual risk

A control does not delete a risk. It moves it down the matrix.



Inherent risk

The risk as it exists with no controls applied at all.

EXAMPLE

An unpatched, internet-facing server holding student records.

Where you start



Residual risk

What remains after your chosen controls are in place.

EXAMPLE

The same server, now patched, firewalled, and behind MFA.

What you actually carry

You accept residual risk, never inherent risk. The whole point of treatment is the distance between the two.

Who decides what is acceptable?

Risk appetite is a management decision, not a technical one



Risk appetite

Set by leadership, in advance.

The broad level of risk an organization is willing to take to pursue its goals.



Risk tolerance

The line drawn on the matrix.

How far a specific risk can stray from appetite before action is required.



Risk owner

Rarely the IT team.

The named person accountable for a given risk and its treatment.

One risk, all the way through

The whole cycle applied to a single, familiar risk

1

Identify

Student enrollment portal, exposed to the internet, on an unpatched web framework.

2

Analyse

Likelihood high - scanners find it fast. Impact high - it holds personal data. Rating: Critical.

3

Evaluate

Critical sits above the school's tolerance line. Action is required, not optional.

4

Treat

Mitigate: patch, put a web firewall in front, restrict access. Residual risk drops to Low.

5

Monitor

Add to the register with a review date. Re-check when the framework issues its next advisory.

KNOWLEDGE CHECK

Question 1 of 4

A firewall and MFA are added to a risky server. The risk that is left afterwards is called...

A

Inherent risk

B

Residual risk

C

Transferred risk

D

Zero risk

KNOWLEDGE CHECK

Question 2 of 4

On a risk matrix, a rare event with catastrophic impact usually lands as...

A

Low, because it is rare

B

High or Critical

C

Medium always

D

It cannot be plotted

KNOWLEDGE CHECK

Question 3 of 4

Deciding how much risk the organization will accept is whose call?

A

The IT team

B

**Leadership / risk
owner**

C

The auditor

D

Whoever is on shift

KNOWLEDGE CHECK

Question 4 of 4

What makes risk management "management" rather than a one-time audit?

A

It is written down

B

The monitor-and-repeat loop

C

It uses a matrix

D

It is done by managers

ACTIVITY

Build a mini risk register

In small groups, run one real risk through the whole cycle



PICK

Choose one risk your school or a workplace you know actually faces.



RATE

Place it on the likelihood-impact matrix and justify the box you chose.



TREAT

Pick a treatment, name a control, and estimate the residual risk that remains.

Name the risk owner too. Who in that organization should actually sign off on what is left?

Six things to carry forward

1

A control that lives in one person's head is a habit, not a control. Write it down.

2

Policy says what and why, standard says exactly what, procedure says how, guideline suggests.

3

ISO 27001 is clauses you must satisfy, plus Annex A controls you justify - not all 93.

4

The risk assessment decides which controls you need. Controls follow risk, never the reverse.

5

A control moves a risk down the matrix. You accept the residual, never the inherent.

6

How much risk to accept is a leadership decision, owned by whoever carries the consequence.